



SISTEMAS DE INFORMACIÓN GERENCIAL

NORMATIVAS Y BUENAS PRÁCTICAS

NORMATIVAS Y BUENAS PRÁCTICAS EN LA PROTECCIÓN DE LA INFRAESTRUCTURA DE TI

La infraestructura de Tecnologías de la Información representa el soporte operativo esencial de las organizaciones contemporáneas. Su protección garantiza la continuidad del negocio, la integridad de la información y la confianza de las partes interesadas. A continuación, se presentan las principales normativas y buenas prácticas aplicables a este ámbito.

Normativas clave en protección de infraestructura de TI

Las normativas internacionales brindan un marco estructurado para gestionar la seguridad de la información:

ISO/IEC 27001:2022

Define los requisitos para establecer un Sistema de Gestión de Seguridad de la Información (SGSI), con base en la gestión de riesgos.

Aplicación: formulación de políticas, auditorías internas, evaluación de riesgos y mejora continua.

ISO/IEC 27002:2022

Complementa la 27001 ofreciendo un catálogo de controles técnicos y organizativos.

Aplicación: implementación de mecanismos de cifrado, controles de acceso, clasificación de la información y gestión de activos.

ISO/IEC 27033-1:2015

Proporciona directrices específicas para proteger redes y comunicaciones.

Aplicación: diseño de redes seguras, segmentación y aseguramiento del tráfico de datos.

Buenas prácticas para la protección de la infraestructura de TI

Además de cumplir con las normativas, las siguientes prácticas fortalecen la seguridad operativa:

Evaluación continua de riesgos

Permite identificar amenazas y vulnerabilidades para priorizar acciones correctivas.

Aplicación: análisis periódico y asignación estratégica de recursos de seguridad.

Gestión de parches y actualizaciones

Reduce vulnerabilidades al mantener sistemas actualizados.

Aplicación: planificación de actualizaciones, pruebas de compatibilidad y control de versiones.

Control de accesos y autenticación

Limita el acceso no autorizado mediante políticas basadas en roles y autenticación multifactor.

Aplicación: segmentación de privilegios, uso de contraseñas robustas y autenticación biométrica o por token.

Capacitación y concienciación del personal

Fortalece la cultura organizacional de seguridad.

Aplicación: capacitaciones periódicas, simulaciones de ataques y campañas educativas.

Ejemplo práctico: SGSI en una pyme del sector logístico

Una empresa logística identifica vulnerabilidades en su infraestructura TI. Decide implementar un SGSI conforme a la ISO/IEC 27001. Define políticas de seguridad, clasifica la información, establece controles de acceso y capacita a su equipo en ciberseguridad. Además, crea un plan de respuesta ante incidentes. Con ello, aumenta su capacidad de recuperación ante eventos críticos y refuerza la confianza de sus clientes.

Tabla 1. Resumen en tabla

Normativa / Práctica	Descripción	Aplicación práctica
ISO/IEC 27001:2022	Requisitos para SGSI basado en riesgos.	Políticas de seguridad, auditorías, mejora continua.
ISO/IEC 27002:2022	Controles y buenas prácticas para complementar la 27001.	Cifrado, gestión de accesos, administración de activos.
ISO/IEC 27033-1:2015	Directrices para seguridad en redes y telecomunicaciones.	Segmentación de redes, protección de datos en tránsito.
Gestión de parches y actualizaciones	Aplicación de actualizaciones para mitigar vulnerabilidades.	Ciclos de actualización planificados y pruebas de compatibilidad.
Capacitación del personal	Prevención de errores humanos mediante formación continua.	Cursos, simulacros y campañas internas de concienciación.

Bibliografía

-  International Organization for Standardization. (2015). ISO/IEC 27033-1:2015 - Information technology — Security techniques — Network security — Part 1: Overview and concepts. <https://www.iso.org/standard/63461.html>
-  International Organization for Standardization. (2022). ISO/IEC 27001:2022 - Information security, cybersecurity and privacy protection — Information security management systems — Requirements. <https://www.iso.org/standard/27001.html>
-  International Organization for Standardization. (2022). ISO/IEC 27002:2022 - Information security, cybersecurity and privacy protection — Information security controls. <https://www.iso.org/standard/75652.html>